

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

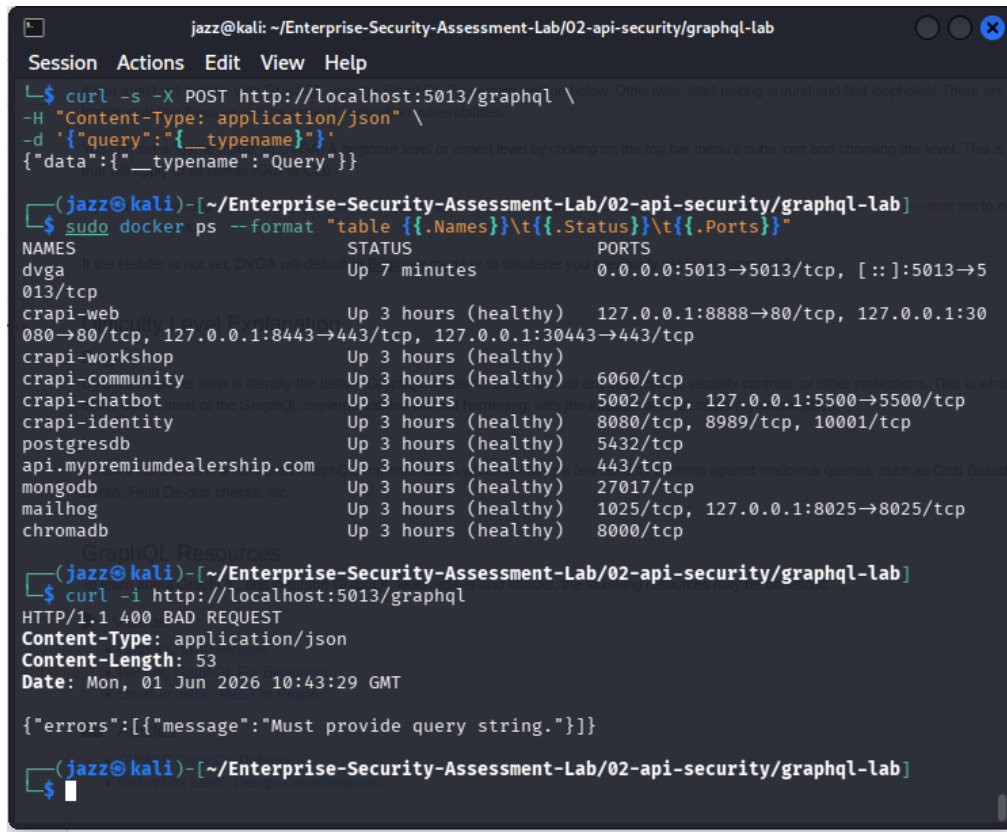
GraphQL Endpoint Availability Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	GraphQL endpoint alive
Result Type	Endpoint availability
Evidence Report File	15-graphql-endpoint-alive-evidence-report.pdf
Testing Phase	GraphQL Endpoint Validation
Tool / Component	curl / Terminal
OWASP / Security Mapping	API9:2023 Improper Inventory Management / GraphQL Exposure
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot



```
jazz@kali: ~/Enterprise-Security-Assessment-Lab/02-api-security/graphql-lab
Session Actions Edit View Help
└─$ curl -s -X POST http://localhost:5013/graphql \
-H "Content-Type: application/json" \
-d '{"query":"{__typename}"}'
{"data":{"__typename":"Query"}}

(jazz@kali)-[~/Enterprise-Security-Assessment-Lab/02-api-security/graphql-lab]
└─$ sudo docker ps --format "table {{.Names}}\t{{.Status}}\t{{.Ports}}"
NAME                STATUS              PORTS
dvga                Up 7 minutes       0.0.0.0:5013→5013/tcp, [::]:5013→5
013/tcp
crapi-web           Up 3 hours (healthy) 127.0.0.1:8888→80/tcp, 127.0.0.1:30
080→80/tcp, 127.0.0.1:8443→443/tcp, 127.0.0.1:30443→443/tcp
crapi-workshop      Up 3 hours (healthy)
crapi-community     Up 3 hours (healthy) 6060/tcp
crapi-chatbot       Up 3 hours          5002/tcp, 127.0.0.1:5500→5500/tcp
crapi-identity      Up 3 hours (healthy) 8080/tcp, 8989/tcp, 10001/tcp
postgresdb          Up 3 hours (healthy) 5432/tcp
api.mypremiumdealership.com Up 3 hours (healthy) 443/tcp
mongodb             Up 3 hours (healthy) 27017/tcp
mailhog             Up 3 hours (healthy) 1025/tcp, 127.0.0.1:8025→8025/tcp
chromadb            Up 3 hours (healthy) 8000/tcp

(jazz@kali)-[~/Enterprise-Security-Assessment-Lab/02-api-security/graphql-lab]
└─$ curl -i http://localhost:5013/graphql
HTTP/1.1 400 BAD REQUEST
Content-Type: application/json
Content-Length: 53
Date: Mon, 01 Jun 2026 10:43:29 GMT

{"errors":[{"message":"Must provide query string."}]}
```

Figure 1 - Embedded screenshot evidence for: GraphQL endpoint alive

What this evidence proves

The evidence shows command-line interaction with the GraphQL endpoint. It confirms endpoint availability and response behaviour.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	GraphQL Endpoint Validation
Tool / Component	curl / Terminal
Assessment Objective	Confirm that the GraphQL endpoint responds to requests and can be tested for schema discovery and query behaviour.
Result Type	Endpoint availability
OWASP / Security Mapping	API9:2023 Improper Inventory Management / GraphQL Exposure

Why this evidence matters

GraphQL endpoint validation confirms where queries are accepted and whether the endpoint is reachable before introspection or resolver-level tests.

Command / workflow used

```
curl -i http://localhost:<port>/graphql  
curl -X POST -H "Content-Type: application/json" -d '{"query":"{__typename}"}' <GRAPHQL_ENDPOINT>
```

Sanitized output style

```
HTTP response reviewed  
GraphQL endpoint reachable  
Headers and status code checked
```

3. Professional Interpretation

This evidence row should be interpreted as: **Endpoint availability**.

An exposed GraphQL endpoint can allow schema discovery, complex query abuse, or unauthorized data access if resolvers are not protected.

Assessor notes

Endpoint alive evidence is a prerequisite for the introspection row.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

An exposed GraphQL endpoint can allow schema discovery, complex query abuse, or unauthorized data access if resolvers are not protected.

Recommended remediation / hardening actions

- Restrict GraphQL access where appropriate.
- Authenticate sensitive resolvers.
- Add depth and complexity limits.
- Monitor query patterns.
- Return minimal error details.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Hostnames if sensitive.
- Tokens.
- Any response containing user data.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[GraphQL endpoint alive](./reports/evidence/15-graphql-endpoint-alive-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.